

NCA Sponsored Training

Day 4 – Afternoon Session (Theory)

Social Engineering

Ahmed Didouh

Madinah

15/01/2026



rc3.kaust.edu.sa





Outline



1. Introduction to Social Engineering

- *Definition*
- *Attack Cycle*

2. Common Social Engineering Attacks

- *Pretexting*
- *Baiting*
- *Phishing*
- *Vishing*
- *Smishing*

3. Technical Defenses

- *Multi-Factor Authentication*
- *Inbound Filtering*
- *Outbound Filtering*



What is Social Engineering



Tactics for **manipulating, influencing, or deceiving** people to gain control over a computer system, or to steal personal and financial information.





Social Engineering, target



Social engineering **uses psychological manipulation to trick users** into making security mistakes or giving away sensitive information.

What is the difference with other methods?





Facts about Social Engineering



- Everyone is a potential target!
- It's often easier for cybercriminals to manipulate a human than a computer network or system.
- Attacks can be relatively low-tech, low-cost, and easy to execute.
- Technology is rapidly accelerating along with the sophistication of attacks.



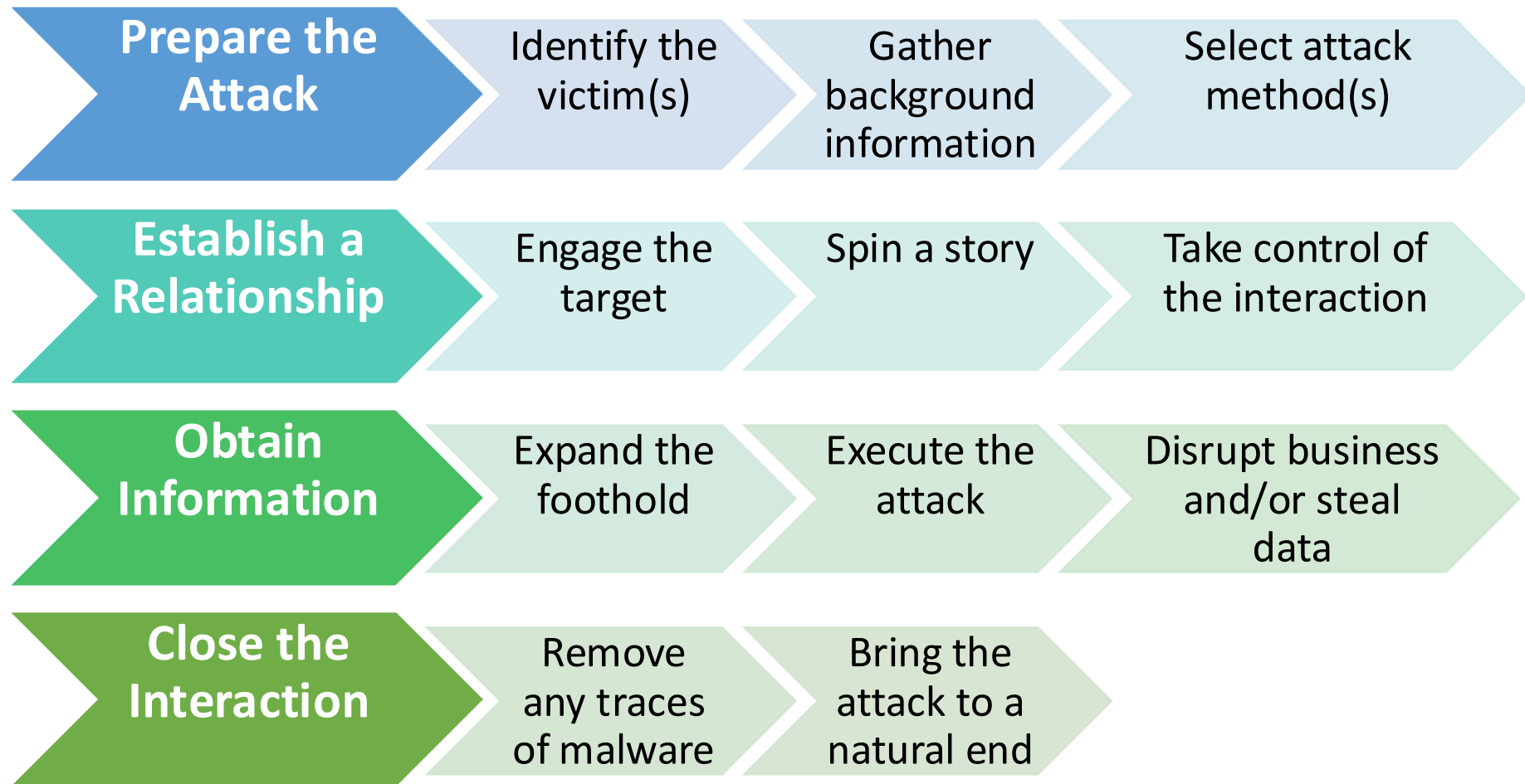
Foundations of Social Engineering Attacks



Social Engineering “MOTIVATIONS”	How it Affects People that Fall for these Social Engineering Techniques
FEAR	Example: You receive a voice mail that you’re under investigation for tax fraud and you must call and pay an immediate fee to the “IRS”
GREED	Example: Someone convinces you that a mere \$10.00 investment will pocket you \$10,000 or more
CURIOSITY	Example: Cybercriminals convince you that some event you see on the news affects you and they have evidence that they send you for review and it is in fact Malware
HELPFULNESS	Example: Playing on the basic desire of humans to trust and help one another – collecting charity and donations for a false cause
URGENCY	Example: You receive a fake or spoofed email from a vendor you use indicating that they need to confirm your credit card information ASAP

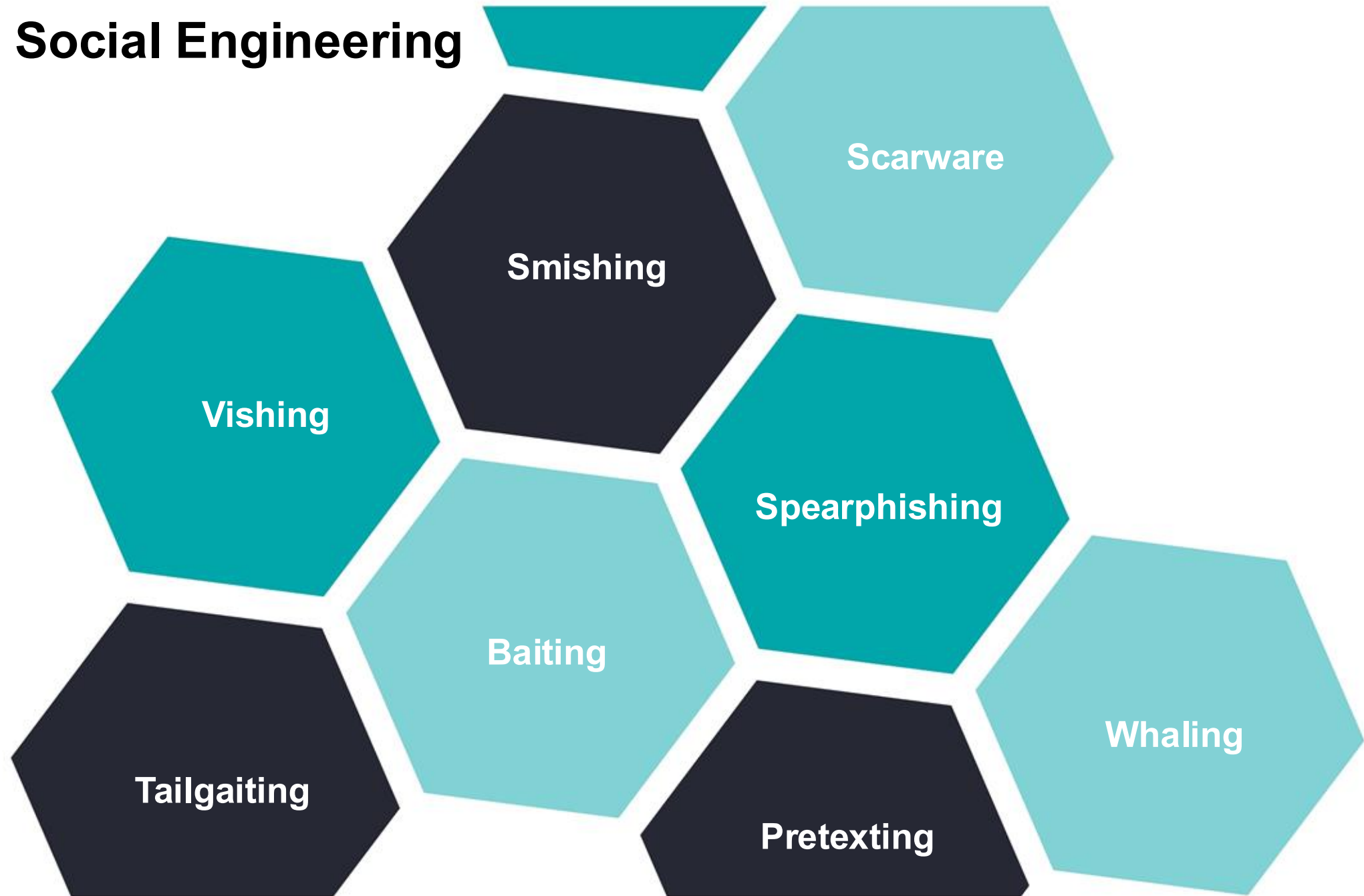


Social Engineering Attack Cycle





Social Engineering





Pretexting



Pretexting is a social engineering technique in which a **fictional** situation is created for the purpose of obtaining personal and sensitive information from an **unsuspecting** individual.

Main elements: a character and a situation.

The *character* is the role the scammer plays in the story

The *situation* is the plot of the scammer's fake story





Pretexting – Techniques and Goals



How is Pretexting done?

- Attackers **impersonate** co-workers, police officers, bankers, tax authorities, or charitable organizations.
- An attacker builds a **credible story** (pretext) that leaves little room for doubt on the part of their target.
- A pretexter may ask a series of questions designed to **gather personally identifiable information**.

Why is it done?

- Obtain Sensitive Information – Credentials, Social security number, place or date of birth or account numbers.
- Or part of another attack



Pretexting – Possible Defenses



- Never give out private information about yourself or anybody else over the phone or internet unless you initiated the contact.
- Discard the call
- Report the sender



Baiting



Involves **offering** something physically or digitally **enticing** to a target in exchange for login information or private data

Yay, a free USB stick 😊





Baiting Techniques



Free Media Download Attackers publish download links on the web, mostly containing malicious software, offering free music, movie, or video games if the target surrenders their login credentials to a certain site.

Unusually low-priced products Attackers advertise extremely low-priced products in an online store they created hoping individuals will attempt to purchase the product and give up their credit or debit card details.

Compromised (bad) USB Drive Infected USB drive used to inject malware, redirect you to phishing websites, or give a hacker access to your computer. E.g., in a conference 😊



Baiting – Possible Defenses



- Think twice before clicking unfamiliar hyperlinks while surfing the web.
- Use reputable retailers when shopping for products or services.
- Do not click on any hyperlinks that offer free music, movie, or video game downloads.
- Avoid any hyperlinks your search engine returns that are classified as ads.
- Do not insert any USB drives into your computer that you find laying around. Turn it into your organizations security team.

Don't be greedy or foolish 😊



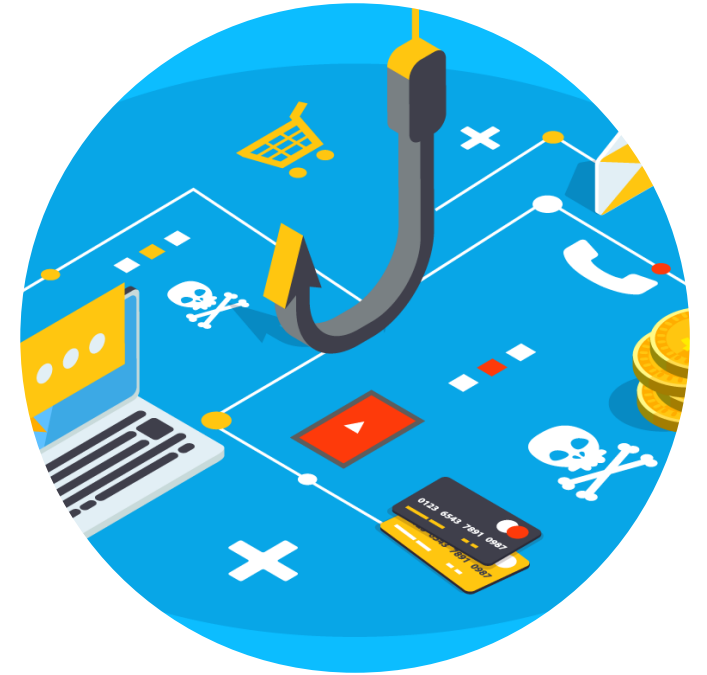
Phishing



A type of attack attacker sends **fraudulent emails**, claiming to be from a reputable and trusted source.

Often used to **steal** user data, including login credentials, personally identifiable information or credit card numbers.

It occurs when an attacker **poses** as a **trusted** entity, dupes a victim into opening an email or instant message. And mostly **dangerous if it has rogue** software



Examples

- Spear Phishing
- Whaling



Phishing, sometimes convincing



Too good to be true

Eye-catching or attention-grabbing offers designed to attract people's attention immediately. For instance, a claim that you have won an iPhone, a lottery, or some other prize

Sense of urgency

- Act fast because the super deals are only for a limited time.
- Your account will be suspended unless you update your personal details immediately.

Hyperlinks/attachments

- Example: Click here to claim your offer, Click here to change your login credentials.
- Often contain ransomware, malware or other viruses.



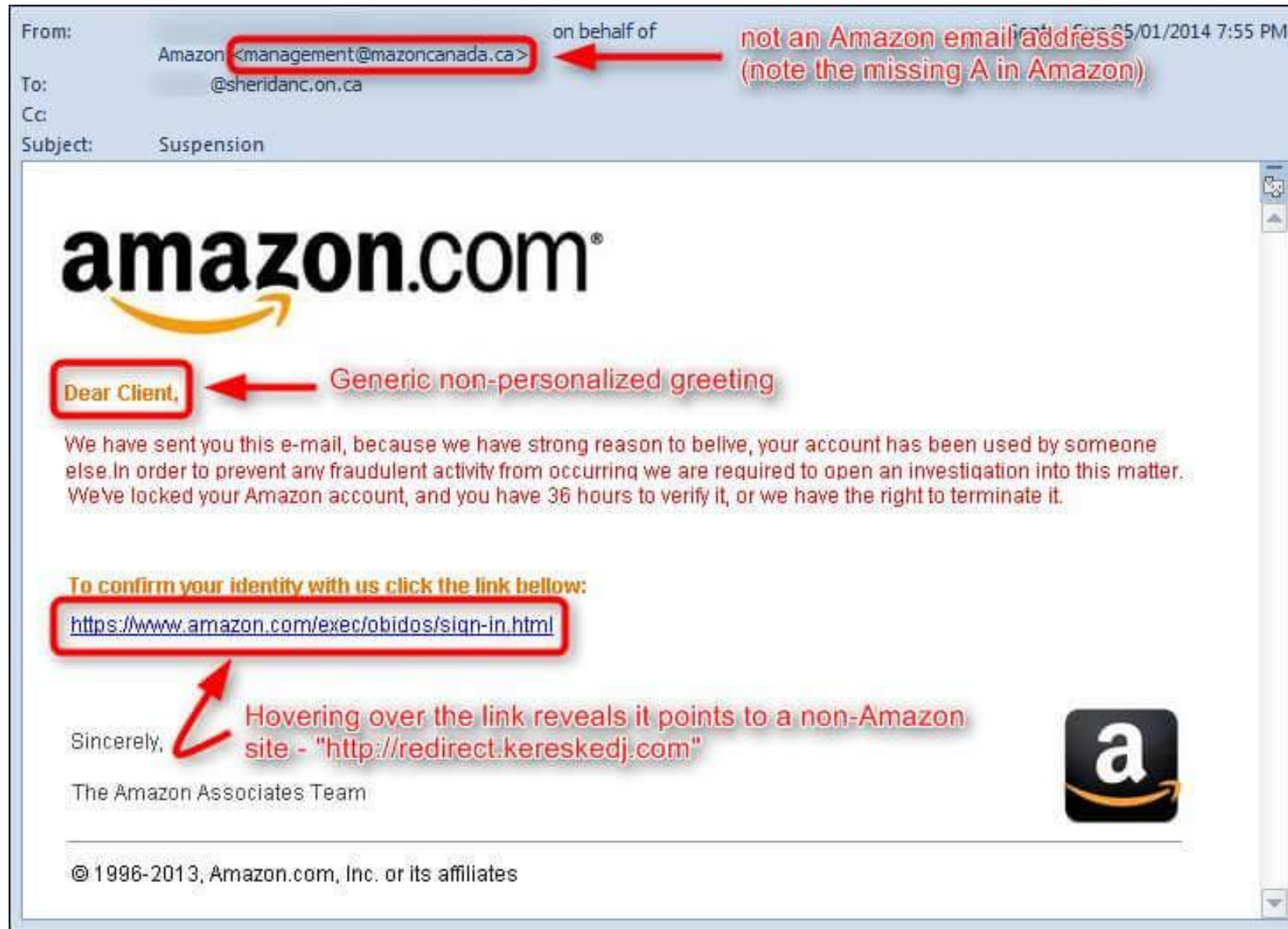
Phishing – Possible Defenses



- Spam filters
- *Human Firewall*
- Check hyperlinks
- Report case
- Discard email and contents
- If in doubt, check with *known* sender using another channel if is correct
- Delete the email or message.



Phishing Email





Phishing Email





Similar Forms to Phishing



Spear Phishing – using directed email

Similar to phishing, spear phishing is an email or electronic communications scam targeted towards a specific individual, organization or business.

Vishing – using voice as medium

An attacker calls their target and uses an automated recording designed to generate fear. The recording will ask the target to call a number to resolve the issue.

Smishing – using small messages, SMS..

An attacker tries to trick you into giving them your private information by sending you a text message.



Malicious computer programs designed to **trick** a user into buying and downloading **unnecessary** and potentially **dangerous software**, such as fake antivirus protection.





How Does Scareware Work?



1. Commonly generates pop-ups that imitate Windows system messages often pretending to be antivirus software. The message usually states that *infected files have been found on the users computer*.
2. An offer to obtain downloadable software to fix the problem is made or the user is advised to call a telephone number displayed in the message for technical support.
3. The user obtains/downloads the software which is effectively useless or allows the attacker that the user called to connect to their computer remotely to install malware.
4. The users money is lost if payment was made, and their computer will most likely become unstable due to the newly installed malware.



Scareware – Possible Defenses



- Always use up-to-date web browsers to ensure the latest security updates are applied.
- Turn on pop-up blockers.
- If you get a pop-up, completely shut down the browser. Use Ctrl-Alt-Delete to close the browser if you are unable to close it normally.
- Do not click any links in a pop-up if you do get one.
- Always keep your antivirus program updated.
- Don't give up personal information requested by a pop-up.



Malicious software (malware) that encrypts victim's hard drive preventing users from accessing the system and their data and demands a ransom payment in order to regain access.





Ransomware - Wannacry

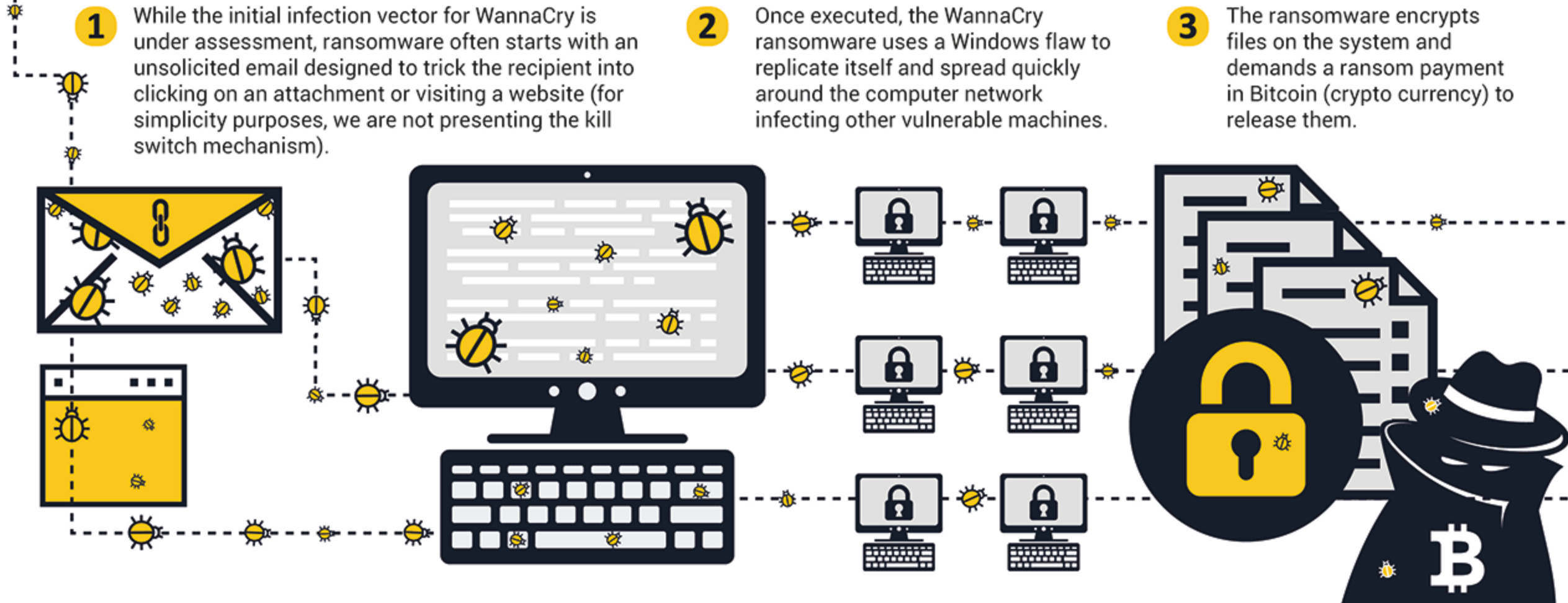


Occurred on May 12, 2017

Impacted more than
200,000 computers in
more than 150 countries.



HOW DOES THE WANNACRY RANSOMWARE WORK?





Things Social Engineering Attackers Know



- A LOT of **company information** is out there, more than you might think
- A LOT of **personal information** is out there, more than you might think
- Security is very vulnerable at **connection points**
- Security is very vulnerable in **exception processes**
- It's easy to send (a lot of) email **as anyone**
- It's easy to call someone appearing to come from **any number**
- In bigger companies, most people don't know each other, but everyone **wants to help**
- Social engineering approaches: **go big or go targeted**
- Most people **avoid advanced security** because "it's hard"



Technical Defenses – Multi-Factor Authentication (MFA)



- Generally, passwords are not good enough
 - If you have to use: length is the most important factor
- MFA is the most effective mitigation
 - However, MFA can't be given away in clever social engineering

MFA Tips:

- Avoid text (SMS) or email
- Best option: authentication apps (e.g., Google Authenticator)
- Consider the recovery process:
 - Social Engineers can probably answer your security questions

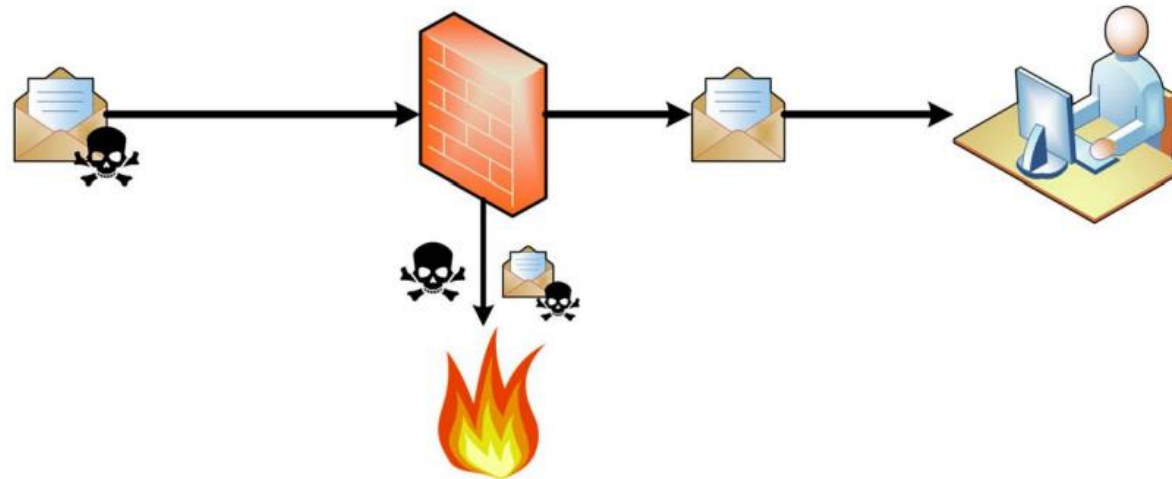




Technical Defenses – Inbound Filtering



- Stop or 'clean' trouble emails before they reach you
- Leverage reputation and collective threat intelligence
- Learn from other users that flag dangerous email, anti-spam
- Authenticating senders

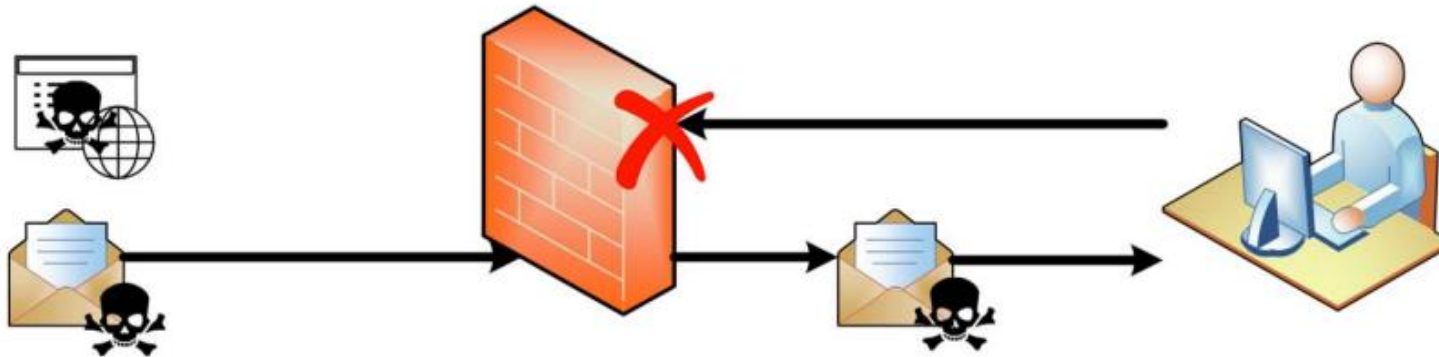




Technical Defenses – Outbound Filtering



- Block that click!
- Stops traffic to “bad neighborhoods”
- Looks for and stops malware call home (Command and Control)
- Watches outbound traffic for likely exfiltration
- Leverages reputation and collective threat intelligence





Cyberattacks are not a joke!



- Cyberattacks are the **fastest growing** crime globally.
- There is a **cyber-attack** every 39 seconds.
- Total cost of **cybercrime** globally has added up to over \$8 trillion in 2023.
- Approximately \$10.5 trillion is expected to be spent annually on cybersecurity by 2025.
- 95% of cybersecurity **breaches** are due to human error.

3.5 Million Cybersec job vacancies





Current Threats in Security:

- Buffer overflow (still there)
- Row Hammer attack
- Side-channel attacks

Do you have any questions?



rc3.kaust.edu.sa



Follow us @rc3kaust

